

Scripts de Conduite d'Entretien — Vulnérabilités Réseau & Détection par IA

Orientés Port Scan & Reconnaissance · 3 Profils ·

[i] **Objet du document** : Chaque section ci-dessous correspond à un profil type d'interviewé. Les réponses proposées sont des **scripts de relance** — elles ne sont pas lues à voix haute, mais servent à guider la conversation vers les problématiques de **scan de ports et de reconnaissance réseau**

★ Profil 1 — Etudiant Avancé en Cybersécurité

→ *Caractéristiques* : Capture et analyse de trafic LAN, familier avec les en-têtes TCP/UDP, les outils d'analyse de trames et les concepts de reconnaissance réseau. Les réponses sont déjà orientées technique — le script sert à enrichir ou préciser.

» Phase 1 — Mise en situation

Introduction

Q1.1 Pourriez-vous vous présenter brièvement et décrire votre rôle ainsi que le type d'architecture réseau que vous gérez ou utilisez au quotidien ?

Je m'appelle (ajouter le prénom). Je suis étudiant ingénieur très orienté sur les problématiques de cybersécurité. J'utilise l'infrastructure locale, mais j'ai aussi l'habitude de capturer et d'analyser le trafic du LAN pour comprendre la structure des paquets qui y circulent.

Q1.2 De manière générale, quels sont les défis ou les incidents majeurs auxquels vous êtes le plus fréquemment confronté pour garantir la disponibilité de cette infrastructure ?

C'est le niveau de "bruit de fond". Il y a énormément de trafic parasite généré par les centaines d'appareils connectés simultanément, ce qui crée de la congestion et masque les vraies menaces.

» Phase 2 — Exploration du problème

Développement

Q2.1 Pourriez-vous me décrire en détail une expérience récente où vous avez constaté un comportement suspect, une anomalie de trafic ou une baisse de performance inexpliquée ?

En laissant tourner un outil de capture pendant un cours, j'ai isolé une série de paquets SYN très espacés dans le temps, tous dirigés vers le segment réseau des serveurs académiques. C'était un scan extrêmement lent et discret.

Q2.2 Selon votre expérience, lorsque le réseau subit ce type de perturbations de manière furtive, quelles en sont les causes les plus courantes ?

C'est clairement de la phase de reconnaissance. Quelqu'un, ou plus probablement une machine compromise, cartographie la topologie pour voir quels services sont exposés avant de tenter d'exploiter une vulnérabilité.

Q2.3 Face à ces anomalies, comment faites-vous la différence entre une simple panne de composant, une inondation de trafic malveillante ou une infection ?

En regardant les en-têtes des paquets. Une inondation classique sature la bande passante. Une reconnaissance sature la table d'état avec beaucoup de requêtes incomplètes vers des ports ouverts ou fermés, générant un ratio anormal de drapeaux SYN et RST.

Q2.4 Les attaquants procèdent souvent par des phases de reconnaissance. Comment percevez-vous ces tentatives de cartographie silencieuse sur votre périmètre ?

Je me concentre sur les anomalies de temps d'arrivée (Inter-Arrival Time). Les attaquants contournent les défenses en faisant des "slow scans", envoyant une sonde toutes les minutes. C'est indétectable sans corrélation sur une longue période.

» Phase 3 — Limites actuelles & transition vers l'innovation

Approfondissement

Q3.1 Actuellement, quelles procédures, logs ou outils mobilisez-vous pour isoler la cause et comment procédez-vous pour bloquer la menace ?

J'applique des filtres d'affichage stricts sur mon analyseur de trames pour isoler les séquences TCP anormales. Ensuite, je peux scripter une liste noire pour bloquer ces sources au niveau de mon propre poste.

Q3.2 Quelles sont les limites techniques ou humaines que vous rencontrez avec ces méthodes actuelles ?

Le temps d'analyse. Entre le moment où le balayage commence et celui où on l'isole manuellement dans les logs, la phase de reconnaissance de l'attaquant est souvent déjà terminée.

Q3.3 Face à la complexité des attaques, que penseriez-vous de l'intégration d'un modèle d'Intelligence Artificielle capable d'analyser le trafic en temps réel pour détecter ces comportements ?

C'est la seule vraie parade technique. Un modèle d'IA entraîné convenablement pourrait évaluer simultanément la fréquence, le nombre d'IP cibles et la taille des paquets sur une fenêtre de temps pour démasquer mathématiquement ces scans.

Q3.4 Pensez-vous qu'un modèle IA serait pertinent non seulement pour détecter, mais aussi pour intervenir directement sur l'infrastructure (ex : bloquer une IP, modifier dynamiquement l'accès) ?

Absolument. D'ailleurs, si on couple l'IA à des Honeypots pour piéger l'attaquant, et qu'on utilise un système dynamique pour changer les ports ouverts, la carte réseau que l'attaquant vient de générer devient fausse en quelques secondes.

» Phase 4 — Critères d'acceptabilité de la solution

Conclusion

Q4.1 Pour qu'une solution basée sur l'IA vous soit réellement utile, quelles devraient être ses caractéristiques principales ?

Un profilage détaillé de la menace : je veux voir l'IP source, le type de balayage déduit par l'IA (SYN, UDP, XMAS), et un historique indiquant si cette source a interagi avec l'un de nos honeypots.

Q4.2 Quelles seraient vos exigences strictes ou vos craintes avant d'autoriser une IA à interagir avec le réseau ?

La confidentialité. Le modèle d'apprentissage doit impérativement se baser uniquement sur les métadonnées réseau (en-têtes IP, TCP/UDP) sans jamais avoir besoin d'inspecter le contenu privé de nos communications (le payload).

Q4.3 En résumé, si ce système intelligent et autonome garantissant un faible taux d'erreur était déployé, seriez-vous prêt à l'adopter ?

Totalement. Une approche combinant machine learning, tromperie et mutation de surface, c'est exactement ce qu'il me faut.

★ Profil 2 — Etudiant Standard (non technique)

- *Caractéristiques* : Utilisateur passif du réseau Wi-Fi académique, sans formation en sécurité. Les réponses sont centrées sur l'expérience utilisateur (lenteur, timeouts). Le script aide à recadrer vers la perception des menaces réseau.

» Phase 1 — Mise en situation

Introduction

Q1.1 Pourriez-vous vous présenter brièvement et décrire votre rôle ainsi que le type d'architecture réseau que vous gérez ou utilisez au quotidien ?

Je m'appelle (ajouter le prénom). Je suis étudiant (ajouter des détails si nécessaire). J'utilise principalement le réseau Wi-Fi de l'école pour accéder aux plateformes pédagogiques, faire de la recherche documentaire et communiquer avec mon groupe de travail.

Q1.2 De manière générale, quels sont les défis ou les incidents majeurs auxquels vous êtes le plus fréquemment confronté pour garantir la disponibilité de cette infrastructure ?

C'est surtout la lenteur extrême à certaines heures. Parfois, il est presque impossible de charger le portail de l'école alors que l'icône réseau m'indique que le signal est au maximum.

» Phase 2 — Exploration du problème

Développement

Q2.1 Pourriez-vous me décrire en détail une expérience récente où vous avez constaté un comportement suspect, une anomalie de trafic ou une baisse de performance inexpliquée ?

Pas plus tard qu'hier, impossible d'envoyer un simple document. Le réseau semblait fonctionner, mais la latence était tellement énorme que la connexion au serveur expirait (time-out) systématiquement.

Q2.2 Selon votre expérience, lorsque le réseau subit ce type de perturbations de manière furtive, quelles en sont les causes les plus courantes ?

Honnêtement, je ne connais pas les détails techniques. J'imagine que c'est lié à des PC infectés qui monopolisent les ressources en arrière-plan sans que leurs propriétaires ne s'en aperçoivent.

Q2.3 Face à ces anomalies, comment faites-vous la différence entre une simple panne de composant, une inondation de trafic malveillante ou une infection ?

Je demande simplement aux étudiants autour de moi s'ils rencontrent le même problème. Si oui, je déduis que c'est une défaillance de l'infrastructure de l'école. Si non, je cherche le problème sur ma machine.

Q2.4 Les attaquants procèdent souvent par des phases de reconnaissance. Comment percevez-vous ces tentatives de cartographie silencieuse sur votre périmètre ?

Je n'ai aucune visibilité là-dessus, ça dépasse totalement mon domaine de compétence. Je constate juste que le réseau est inutilisable et j'attends que ça revienne à la normale.

» Phase 3 — Limites actuelles & transition vers l'innovation

Approfondissement

Q3.1 Actuellement, quelles procédures, logs ou outils mobilisez-vous pour isoler la cause et comment procédez-vous pour bloquer la menace ?

Quand mon ordinateur est très lent sur le réseau, je lance un scan avec mon antivirus classique et je ferme les applications qui consomment de la bande passante, en espérant que ça aide.

Q3.2 Quelles sont les limites techniques ou humaines que vous rencontrez avec ces méthodes actuelles ?

Je suis complètement dépendant de la réactivité du service informatique. Trouver la source d'un problème réseau demande des compétences et des accès que je ne possède pas.

Q3.3 Face à la complexité des attaques, que penseriez-vous de l'intégration d'un modèle d'Intelligence Artificielle capable d'analyser le trafic en temps réel pour détecter ces comportements ?

Si cela permet d'automatiser la sécurité du campus et de garantir une connexion fluide en bloquant les éléments perturbateurs à la source, c'est une excellente idée.

Q3.4 Pensez-vous qu'un modèle IA serait pertinent non seulement pour détecter, mais aussi pour intervenir directement sur l'infrastructure (ex : bloquer une IP, modifier dynamiquement l'accès) ?

Tant que cette intervention est transparente pour mon utilisation quotidienne et que je n'ai pas de configuration complexe à faire de mon côté, je trouve ça très pertinent.

» Phase 4 — Critères d'acceptabilité de la solution

Conclusion

Q4.1 Pour qu'une solution basée sur l'IA vous soit réellement utile, quelles devraient être ses caractéristiques principales ?

J'ai besoin d'un tableau de bord avec des graphiques simples. Une simple notification ou un indicateur d'état (vert/rouge) dans la barre des tâches pour m'informer de la santé du réseau me suffirait.

Q4.2 Quelles seraient vos exigences strictes ou vos craintes avant d'autoriser une IA à interagir avec le réseau ?

Ma principale exigence est la garantie de la vie privée. L'IA doit sécuriser le réseau sans tracer ni analyser le contenu de mes recherches documentaires ou de mes projets.

Q4.3 En résumé, si ce système intelligent et autonome garantissant un faible taux d'erreur était déployé, seriez-vous prêt à l'adopter ?

Oui, à condition que le résultat final soit un réseau académique plus rapide et beaucoup plus stable.

★ Profil 3 — Administrateur Systèmes et Réseaux

- *Caractéristiques* : Infrastructure hybride LAN/VPN/Cloud en production. Maîtrise des pare-feux, SIEM, ACL, slow scans distribués et Moving Target Defense. Les réponses sont riches et opérationnelles — le script ancre la discussion dans les besoins de déploiement réel d'un IDS/IPS basé sur l'IA.

» Phase 1 — Mise en situation

Introduction

Q1.1 Pourriez-vous vous présenter brièvement et décrire votre rôle ainsi que le type d'architecture réseau que vous gérez ou utilisez au quotidien ?

Je m'appelle (ajouter le prénom). Je suis l'Administrateur Systèmes et Réseaux pour une entreprise. Je gère une infrastructure hybride classique : un réseau LAN sécurisé pour nos collaborateurs sur site, des tunnels VPN pour le télétravail, et des serveurs Cloud hébergeant nos applications métiers (ERP, CRM) exposés sur Internet.

Q1.2 De manière générale, quels sont les défis ou les incidents majeurs auxquels vous êtes le plus fréquemment confronté pour garantir la disponibilité de cette infrastructure ?

Mon plus grand défi est l'équilibre entre l'accessibilité et la sécurité. Je dois m'assurer que nos employés et partenaires accèdent aux données sans latence, tout en repoussant les menaces externes (ransomwares, attaques ciblées) qui sondent continuellement notre périmètre exposé.

» Phase 2 — Exploration du problème

Développement

Q2.1 Pourriez-vous me décrire en détail une expérience récente où vous avez constaté un comportement suspect, une anomalie de trafic ou une baisse de performance inexplicable ?

Récemment, les alertes de notre pare-feu de périphérie se sont multipliées. Il n'y avait pas de pic de bande passante, mais les journaux montraient des milliers de paquets de type "SYN" (tentatives de connexion) dirigés vers des ports internes non standards, provenant de diverses adresses IP externes, à des intervalles très irréguliers.

Q2.2 Selon votre expérience, lorsque le réseau subit ce type de perturbations de manière furtive, quelles en sont les causes les plus courantes ?

C'est systématiquement de la reconnaissance active. Avant de lancer une attaque ciblée pour exfiltrer des données ou déployer un ransomware, les attaquants utilisent des scripts pour cartographier silencieusement nos vulnérabilités et identifier les services qui tournent sur nos serveurs.

Q2.3 Face à ces anomalies, comment faites-vous la différence entre une simple panne de composant, une inondation de trafic malveillante ou une infection ?

Les métriques parlent d'elles-mêmes. Une panne provoque un silence (plus de paquets de retour). Un DDoS sature nos tuyaux. Un scan de ports furtif se repère en analysant la table d'état de notre routeur : on observe une explosion de connexions TCP laissées "à moitié ouvertes" (half-open) et une forte proportion de paquets de rejet (RST) renvoyés par nos ports fermés.

Q2.4 Les attaquants procèdent souvent par des phases de reconnaissance. Comment percevez-vous ces tentatives de cartographie silencieuse sur votre périmètre ?

Les scans agressifs classiques sont bloqués par nos systèmes actuels. En revanche, les "slow scans" ou balayages distribués sont notre angle mort. L'attaquant envoie une sonde toutes les 5 minutes depuis des adresses IP différentes. Cela se noie dans le trafic légitime de l'entreprise et ne déclenche pas nos alarmes basées sur des seuils de volume.

» Phase 3 — Limites actuelles & transition vers l'innovation

Approfondissement

Q3.1 Actuellement, quelles procédures, logs ou outils mobilisez-vous pour isoler la cause et comment procédez-vous pour bloquer la menace ?

L'équipe doit centraliser et corréler manuellement les logs via un SIEM (outil de gestion des événements de sécurité). Une fois l'anomalie détectée et l'adresse IP confirmée comme malveillante, nous ajoutons une règle de blocage "Deny" dans les listes de contrôle d'accès (ACL) de notre pare-feu.

Q3.2 Quelles sont les limites techniques ou humaines que vous rencontrez avec ces méthodes actuelles ?

C'est toujours une réaction "post-mortem". Le temps qu'un analyste repère la corrélation temporelle du scan lent et applique le blocage, l'attaquant a souvent déjà fini de cartographier notre infrastructure ou a changé d'adresse IP.

Q3.3 Face à la complexité des attaques, que penseriez-vous de l'intégration d'un modèle d'Intelligence Artificielle capable d'analyser le trafic en temps réel pour détecter ces comportements ?

Ce serait un changement de paradigme. Une IA (comme un modèle Random Forest) qui raisonne sur des fenêtres glissantes et non sur des seuils fixes comblerait exactement les lacunes de nos règles statiques. Elle détecterait la signature mathématique d'un balayage furtif en temps réel.

Q3.4 Pensez-vous qu'un modèle IA serait pertinent non seulement pour détecter, mais aussi pour intervenir directement sur l'infrastructure (ex : bloquer une IP, modifier dynamiquement l'accès) ?

Absolument. L'automatisation de la riposte est l'avenir. Et j'apprécie particulièrement l'approche du Moving Target Defense. Si l'IA détecte un scan et modifie dynamiquement les ports de nos services internes en arrière-plan, toutes les informations que l'attaquant a mis des heures à collecter deviennent instantanément fausses, sans que cela n'impacte nos employés.

» Phase 4 — Critères d'acceptabilité de la solution

Conclusion

Q4.1 Pour qu'une solution basée sur l'IA vous soit réellement utile, quelles devraient être ses caractéristiques principales ?

Nous avons besoin d'un tableau de bord de type SOC (Security Operations Center) fournissant un profil clair de la menace : type de scan identifié, adresses MAC, cibles visées, et surtout le niveau de confiance (score) de la prédiction de l'IA pour justifier son intervention.

Q4.2 Quelles seraient vos exigences strictes ou vos craintes avant d'autoriser une IA à interagir avec le réseau ?

Ma ligne rouge, c'est la disponibilité du réseau métier (faux positifs). L'IA ne doit en aucun cas bloquer un flux légitime, comme la communication entre notre serveur web et notre base de données comptable. De plus, les rotations MTD doivent être parfaitement synchronisées avec nos clients légitimes.

Q4.3 En résumé, si ce système intelligent et autonome garantissant un faible taux d'erreur était déployé, seriez-vous prêt à l'adopter ?

Oui. Coupler l'IA pour la détection comportementale, des honeypots pour dévier la menace, et le MTD pour muter l'architecture, c'est exactement ce qu'il faut à une entreprise moderne pour passer d'une posture de sécurité passive à une vraie défense active.
